



HIPAA COMPLIANCE FOR HEALTHCARE

My Compliance

HIPAA Edition

HIPAA Compliance. Operationalized. — Security Rule, Privacy Rule, and Breach Notification Rule alignment for covered entities and business associates, powered by commercial tools and 25+ years of healthcare IT expertise.

18

HIPAA IDENTIFIERS

BAA

SUPPORTED

PHI

GRADE CONTROLS

100%

AUDIT-READY

The HIPAA Compliance Challenge

Healthcare organizations know HIPAA inside-out on paper — but the Security Rule, Privacy Rule, and Breach Notification Rule have to be operationalized across EHRs, email, BYOD, cloud SaaS, and every business associate. That's where most programs break.



PHI Sprawl

Electronic PHI lives in the EHR, email, file shares, BYOD, SaaS apps, and backups. Most organizations can't inventory where PHI resides — let alone protect it.

→ PHI data mapping & minimum-necessary controls



BAA Management Chaos

Every vendor handling PHI requires a Business Associate Agreement. Tracking agreements, renewals, and vendor security posture is a manual spreadsheet exercise — until OCR asks.

→ Centralized BAA lifecycle & vendor posture tracking



Access Control Gaps

HIPAA requires role-based access, minimum-necessary use, unique user IDs, and strict termination processes. Most organizations have holes in all of them — and no audit trail to prove otherwise.

→ Technical Safeguards + identity & access controls



Breach Notification Clock

HIPAA gives you 60 days to notify after a reportable breach. Without monitoring, DLP, and incident response playbooks, you miss the detection — and blow the clock.

→ Detection, IR playbooks & OCR-ready reporting

Why HIPAA Now?

- ▶ OCR audit activity is intensifying — enforcement priorities now emphasize risk analysis, right-of-access, and Security Rule fundamentals across practices of every size
- ▶ Ransomware attacks targeting healthcare have roughly doubled year-over-year, and HHS now treats most ransomware events as presumptive breaches
- ▶ HHS has imposed record-breaking HIPAA penalties, with multi-million-dollar resolutions for inadequate risk analyses, missing BAAs, and delayed notifications
- ▶ State privacy laws (California CMIA, Washington My Health My Data, and others) are stacking on top of HIPAA — raising the compliance floor for every healthcare organization

HIPAA Service Pillars

We operationalize the full HIPAA ruleset — Administrative, Physical, Technical safeguards, plus Breach Readiness — so your program holds up to OCR review.

Administrative Safeguards

- ✓ HIPAA policies & procedures library
- ✓ Workforce training & attestation
- ✓ Security & Privacy Risk Assessments
- ✓ Contingency planning & disaster recovery
- ✓ Incident response & sanction policy
- ✓ Business Associate Agreement (BAA) management

Physical Safeguards

- ✓ Facility access controls & visitor logs
- ✓ Workstation use & security policy
- ✓ Device & media controls (inventory, tracking)
- ✓ Secure disposal & sanitization procedures
- ✓ Server room & data center physical security
- ✓ Mobile device & BYOD hardening

Technical Safeguards

- ✓ Access control & unique user identification
- ✓ Audit controls & log review
- ✓ Integrity controls for ePHI
- ✓ Person/entity authentication (MFA)
- ✓ Transmission security (TLS, encryption)
- ✓ Encryption at rest across EHR, backups, endpoints

Breach Readiness & Response

- ✓ PHI-aware detection & monitoring
- ✓ 60-day breach notification clock management
- ✓ Forensic readiness & evidence preservation
- ✓ OCR reporting & regulator communications
- ✓ Media & patient notification templates
- ✓ Post-incident remediation & lessons learned

How We Engage

1

Gap Assess

HIPAA gap assessment across all three rules



2

Roadmap

Prioritized remediation roadmap by risk



3

Implement

Policies, controls & evidence binder



4

Operate

Ongoing monitoring + annual risk assessment

HIPAA Use Cases

Representative HIPAA engagements we design and operate — anonymized profiles drawn from our healthcare compliance practice. Covered entities and business associates alike.

MEDICAL PRACTICE

Medical Practice HIPAA Readiness

Multi-provider medical practice achieving Security Rule alignment across EHR, Microsoft 365, secure email, and Veeam backup — with policies, workforce training, and audit-ready evidence.

EHR
+ M365

Audit
Ready

PHI DATA MAPPING

PHI Inventory & Minimum-Necessary

Healthcare organization inventorying every location where PHI resides — EHR, shared drives, email archives, SaaS, and backups — then enforcing minimum-necessary access and DLP controls.

Full
PHI Map

DLP
Enforced

RANSOMWARE RECOVERY

Healthcare Ransomware Recovery & OCR Reporting

Post-breach recovery for a healthcare organization: containment, forensics, 60-day breach notification, OCR reporting, and a remediation program to close the gaps that caused the incident.

60d
Clock met

OCR
Reported

BUSINESS ASSOCIATE

SaaS Business Associate Gearing Up

HealthTech SaaS vendor handling PHI stood up Technical Safeguards, encryption in transit/rest, audit logging, BAA program, and vendor risk management — enabling contracts with covered entities.

BAA
Program

Tech
Safeguards

ANNUAL PROGRAM

Annual HIPAA Risk Assessment

Recurring annual risk assessment and evidence refresh for a mature HIPAA program — including policy updates, BAA renewals, workforce retraining, and control effectiveness testing.

Annual
Cadence

Evidence
Refreshed

Engagement Models

Flexible ways to engage — from a focused gap assessment to a fully managed HIPAA program with a fractional Privacy or Security Officer.

HIPAA Readiness Assessment

Fixed-fee gap assessment against Security Rule, Privacy Rule, and Breach Notification Rule with a prioritized roadmap.

- ✓ Administrative, Physical, Technical Safeguards review
- ✓ Risk analysis per 164.308(a)(1)(ii)(A)
- ✓ BAA inventory & vendor posture check
- ✓ Executive-ready findings & remediation plan

Best for: Baselining your program or preparing for OCR

HIPAA Program Implementation

Six-month fixed-scope engagement to stand up a full HIPAA program end-to-end with evidence binders.

- ✓ Policies, procedures & workforce training
- ✓ Technical Safeguards deployment & tuning
- ✓ BAA program & vendor risk rollout
- ✓ OCR-ready audit evidence binder

Best for: Covered entities and business associates building programs

Managed HIPAA Program

Monthly retainer keeping your HIPAA program running, evidence fresh, and incidents handled.

- ✓ Continuous policy, BAA & evidence lifecycle
- ✓ Vulnerability scanning & monitoring
- ✓ Incident response on standby
- ✓ Annual risk assessment refresh

Best for: Organizations without a dedicated HIPAA team

Fractional Privacy / Security Officer

A retained HIPAA Privacy Officer, Security Officer, or vCCO attending leadership and regulators on your behalf.

- ✓ Named HIPAA Privacy / Security Officer
- ✓ Board & executive reporting
- ✓ OCR correspondence & audit defense
- ✓ Workforce & leadership guidance

Best for: Practices & HealthTech without an in-house officer

Healthcare Segments We Serve



Medical Practices



Dental Practices



Behavioral Health



Specialty Clinics



Labs & Imaging



DME Providers



HealthTech SaaS (BA)



Healthcare MSPs

Ready for Your Next OCR Audit?

Start with a HIPAA Gap Assessment or an executive Compliance Workshop — scoped to your EHR, your vendors, and your risk profile. Walk away with a roadmap that holds up to regulators.

HIPAA Gap Assessment

Compliance Workshop

rjain@technijian.com | (949) 379-8499 x201 | technijian.com

About Technijian — HIPAA Compliance Practice

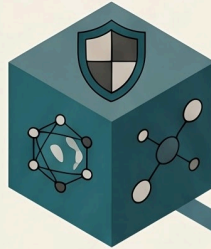
Technijian's HIPAA practice combines 25+ years of healthcare IT experience with best-in-class commercial compliance tools — N-able Passport for credentials, Network Detective by RapidFire Tools for HIPAA risk assessments, Pentest-Tools.com for external vulnerability scans, Teramind for PHI DLP and user activity monitoring, and Veeam for HIPAA-compliant backup. We deliver deep expertise across the Security Rule, Privacy Rule, and Breach Notification Rule — operationalized through policies, controls, and evidence that stand up to OCR. HIPAA program clients get priority migration to Nexus Compliance when the Technijian platform launches.

HIPAA Compliance Service Map

Administrative, Physical, and Technical Safeguards — delivered by Technijian

Technijian My Compliance: The HIPAA Edition

THE THREE PILLARS OF HIPAA COMPLIANCE

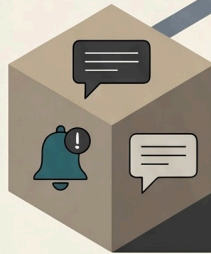


THE SECURITY RULE

Establishes national standards to protect electronic PHI through three specific safeguards: Administrative (policies and training), Physical (facility access and device security), and Technical (encryption and access controls).

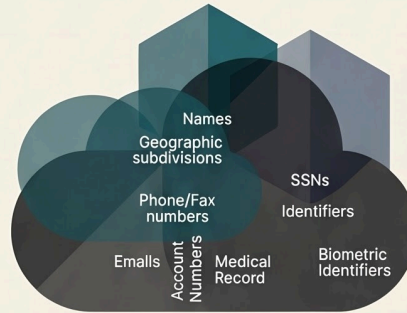
THE PRIVACY RULE

Sets the standards for how Protected Health Information can be used and disclosed, ensuring individuals' health information is properly protected while allowing the flow of health information needed to provide high-quality care.



THE BREACH NOTIFICATION RULE

Requires HIPAA-covered entities and their business associates to provide notification following a breach of unsecured protected health information to affected individuals, the HHS Secretary, and, in some cases, the media.



PROTECTING PHI & THE 18 IDENTIFIERS

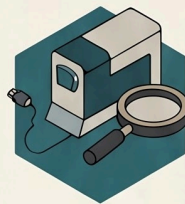
HIPAA requires the removal of 18 specific identifiers to de-identify health information.



BUSINESS ASSOCIATE AGREEMENT (BAA)

A mandatory contractual assurance that any third-party "Business Associate" (like Technijian) will appropriately safeguard PHI in accordance with HIPAA requirements.

TECHNIJIAN'S HIPAA SERVICE OFFERINGS



RISK ASSESSMENTS & AUDITS

Utilizing "My Compliance — Assess" to perform internal network audits, AD reviews, and external vulnerability scans to identify security gaps.



POLICY & PROCEDURE LIFECYCLE

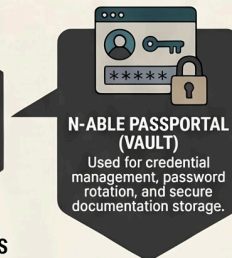
Through "My Compliance — Govern," Technijian manages the lifecycle of manual documents, SOPs, and runbooks to ensure framework alignment.

PROFESSIONAL COMPLIANCE TECH STACK



SECURITY CONTROLS & PHI SHIELDING

Implementing "My Compliance — Shield" for data loss prevention (DLP) and "My Compliance — Vault" for secure credential and secrets management.



N-ABLE PASSPORTAL (VAULT)

Used for credential management, password rotation, and secure documentation storage.



TERAMIND (SHIELD)

Provides endpoint DLP, user activity monitoring, and insider threat detection to prevent PHI leaks.



AUDIT PREP & EVIDENCE COLLECTION

Manual "Audit Sherpa" services that organize evidence folders and audit packs from various tool exports to ensure readiness for certification.



HIPAA Compliance for Healthcare

technijian.com